



Example: A corporate policy mandates 8-character alphanumeric passcodes on all iOS devices, with a 30-minute lockout and device wipe after 10 failures.

Biometric authentication

Biometrics add “something you are” to your security stack, improving both usability and protection when implemented correctly.

Secure enrollment and fallback

1. Enroll under controlled conditions

- **Android:** Settings → Security → Biometric Preferences → Fingerprint → Add fingerprint; ensure the device is dry and sensor is clean.
- **iOS:** Settings → Face ID & Passcode → Enroll Face ID; rotate your head slowly to capture multiple angles.

2. Require PIN fallback

- Both platforms mandate a PIN or password fallback if biometric fails, ensuring you still retain “something you know”.

3. Limit enrollment count

- Avoid enrolling multiple fingerprints/faces for different people; ideally limit to two fingers or a single face to reduce attack surface.

Best practices and hardening

- **Liveness detection:** Ensure your device supports anti-spoofing (e.g., Apple’s infrared dot projector or Android’s secure face maps).
- **Disable on lock screen:** Require unlock passcode before biometric enrollment changes.
- **Audit usage:** Periodically review which apps use biometrics (Settings → Apps → [App] → Permissions → Biometrics).

Example: On a Google Pixel, liveness detection blocks printed-photo spoofs, while the fallback PIN prevents brute-force after face-recognition failures.

Multi-Factor Authentication (MFA)

MFA strengthens “something you have” on top of passwords. We’ll configure both TOTP and push-based methods.

TOTP Setup

1. Install an Authenticator app

- Google Authenticator, Microsoft Authenticator, or Authy on iOS/Android.

2. Enable TOTP in accounts

- **Example (GitHub):** Settings → Security → Two-factor authentication → Set up using an authenticator app.

3. Scan QR code

- In the authenticator app, tap Add account → Scan barcode; verify 6-digit code sync.

4. Store Backup Codes

- Save one-time backup codes in your password manager for recovery.



Push-Based MFA

1. Use a Push-MFA provider

- Duo Mobile, Microsoft Authenticator, or Google Prompt.

2. Enroll device

- On first login, add the account in the app; verify via push notification.

3. Configure notifications

- Ensure Allow Notifications for the authenticator app so approvals come through without unlocking.

4. Set fallback to TOTP or SMS?

- Disable SMS fallback where possible – per CISA advice, SMS is vulnerable to SIM-swap attacks.

Best practice: Mandate MFA for all VPN, email, and administrative console logins, combining push approval with device-bound certificates where feasible.

Passkeys: Passwordless authentication

Passkeys (FIDO2/WebAuthn) provide phishing-resistant, passwordless login using asymmetric cryptography.